

通用设计标准模板

15 个核心问题

适用对象	产品、架构、研发、项目、售前、评审人员
使用方式	围绕具体课题逐项填写，形成完整设计说明
输出目标	把“为什么做、为什么这样设计、如何落地”讲清楚

核心问题清单

使用要求：每个问题都应结合具体课题填写，避免空泛表述。回答时应同时覆盖业务背景、设计逻辑、技术判断和落地路径。

1. 这个课题到底要解决什么问题？

填写要点

• 当前要处理的核心问题是什么？

为中交集团（甲方）构建一个能够完全替代“腾讯云枢”，并满足其“自主可控、安全可信、高性能、可深度定制”要求的下一代企业级零信任安全网关（“新云枢”）。

• 这个问题具体表现在哪些业务、流程或系统环节？

业务层面：

外部访问依赖：
集团全球数万名员工、数百家供应商，其访问内部 OA、ERP、财务、BIM、招采等数百个核心业务系统的通道，目前完全依赖腾讯云枢。这是一个单点核心依赖。

业务连续性风险：
原供应商（腾讯）的产品即将停服/强制升级，若无法平滑迁移，将直接导致业务访问中断，影响全球项目和日常运营。

技术与管理层面：

“黑盒”与失控：
作为商业 SaaS/托管服务，腾讯云枢是一个“黑盒”。中交无法掌握其核心代码、安全策略实现细节、数据流转路径，无法进行深度安全审计和定制化开发，不符合央企对关键基础设施的“自主可控”要求。

数据主权与合规风险：
所有访问流量和策略数据经腾讯云处理，存在潜在的数据出境和敏感信息泄露风险，难以满足等保 2.0 三级、关基条例以及国资监管对数据主权的严格要求。

技术栈锁死与扩展性不足：
无法与中交内部现有的国产化技术栈（如达梦数据库、麒麟 OS）深度集成，也无法针对其特有的业务场景（如智慧工地物联网协议、超大 BIM 文件传输优化）进行定制开发，技术发展受制于人。

• 如果不解决，会带来哪些影响或损失？

直接业务中断：导致项目停工、协同停滞、招投标延误，造成巨额经济损失。

长期战略被动：

安全失控：继续使用外部商业服务，安全命脉掌握在他人手中，无法应对国家级 APT 攻击或供应链安全威胁。

成本失控：将长期支付高额服务费，且无法预测未来涨价。

创新受阻：无法将安全能力与自身业务深度结合，难以孵化如“智慧工地安全大脑”、“供应链金融可信访问链”等创新应用，在数字化转型中失去竞争力。

合规与审计风险：无法向国资委、审计署等监管机构证明其核心网络通道的完全自主与安全可控，可能面临通报、处罚的风险。

2. 为什么现在必须做？

填写要点

- 触发本课题的直接背景是什么？

供应商“停服”【业务连续性风险】，“黑盒”失控【安全上完全不可控】

- 是客户需求、业务变化、技术瓶颈、合规要求，还是竞争压力所驱动？

首要驱动是“合规”和“自主可控”

技术瓶颈：腾讯云枢是通用产品，针对中交特有的超大 BIM 文件传输、海外项目高延迟、与内部复杂系统（如达梦数据库、企业微信）深度集成等场景，要么性能不够，要么根本做不了。客户需要一个能“深度定制、按需优化”的解决方案，而不是一个标准化的“盒子”。

业务变化：数字化转型越深入，对内网服务的访问需求就越复杂、越精细。旧的架构已经跟不上，必须用一个更灵活、可编程的新架构来支撑未来 5-10 年的业务演进。

- 为什么当前时间点启动最合适？

腾讯云 API 网关“停服”前，是最后的迁移窗口期。与信创大潮同频。

3. 本轮设计的目标是什么？

填写要点

- 本轮希望达成的核心结果是什么？

向中交集团交付一个可私有化部署、具备完整“零信任”核心功能、并能实际接管其部分生产业务流量的“新云枢”最小可行产品（MVP）。它不是一个演示原型，而是一个能上生产、可运维、有明确升级路径的企业级基础软件产品。

- 成功后应形成哪些明确能力、产出或效果？

明确的能力：

零信任安全接入能力：支持基于 JWT（用户身份）和 mTLS（设备/服务身份）的强认证与动态授权，实现“从不信任，总是验证”。

应用隐身与隧道接入能力：通过 stealth-tunnel-agent+ sag-connector 组件，实现内网应用零端口暴露，仅通过加密隧道访问。

统一策略管控能力：通过 control-plane-admin 和 sag-policy，提供集中式的路由、上游、ABAC 策略的配置、存储与下发能力。

内网 API 治理能力：通过集成 APISIX，提供动态路由、负载均衡、基础限流等 API 网关功能，作为隧道流量的内网分发枢纽。

基础可观测能力：系统关键组件（网关、Agent、服务）可输出结构化日志和基础指标，支持问题排查。

明确的产出：

一组可独立部署的 Rust 微服务二进制：包括 control-plane-admin, sag-auth, sag-policy, stealth-tunnel-agent, sag-connector, http-tunnel-bridge。

一个基于 Zentinel 的生产就绪网关：配置了 TLS 和基础路由规则，可作为对外统一入口。

一套完整的管理配置：包括数据库（SQLite）Schema、APISIX 路由模板、证书配置等。

部署与运维文档：明确的生产环境部署手册、启动顺序、健康检查与故障排查指南。

管理后台与用户门户 Demo：提供基础的 Web 界面，供管理员配置路由、策略，供用户测试访问。

明确的效果：

业务效果：甲方 IT 团队能够通过本系统，成功、安全地发布至少 1-2 个内网业务应用（如测试环境 OA 或文档系统），供指定员工通过互联网访问，用户体验不劣于原腾讯云枢。

管控效果：甲方管理员能够通过管理后台，完成用户/应用/策略的增删改查，并观察到配置实时生效。

安全效果：实现网络层（隧道加密）、身份层（JWT/mTLS）、应用层（ABAC 策略）的纵深防御，访问日志可查。

• 目标应如何量化或验证？

端到端冒烟测试；控制面 API 全覆盖测试；配置持久化验证（重启）；APISIX 集成验证；隧道高可用验证；性能基准；安全审计；部署验证。

4. 本轮明确不做什么？

填写要点

• 哪些内容不属于本轮范围？

完整的低代码应用搭建平台（模块 4 的非核心部分）

终端安全深检客户端（模块 7 的增强功能）

终端安全深检客户端（模块 7 的增强功能）

全功能服务网格（Service Mesh）的部署与运维：内网应用东西向治理

• 哪些需求可以后置，避免范围失控？

高阶 API 网关功能

多租户体系的完整实现

与所有潜在身份源（IdP）的对接

图形化的策略编辑器

• 边界在哪里，如何避免与相邻系统或课题重复建设？

与现有内网负载均衡/API 网关的边界

与客户现有身份系统（4A/IAM）的边界

与未来可能引入的服务网格（Mesh 东西向）的边界

与运维监控体系（如 Zabbix、Prometheus）的边界

5. 这个课题服务谁？

填写要点

- 目标用户、目标客户或关键角色分别是谁？

中交集团 作为组织实体，是本次项目的购买方和最终拥有者

- 谁是直接使用者，谁是决策者，谁是受影响方？

角色分类	具体角色	职责描述
直接使用者	全体员工	通过本系统访问内网OA、ERP、BIM、财务等应用完成日常工作。
	合作伙伴/供应商	通过专属门户访问招采平台、项目协同系统等。
管理员/运维者	IT 基础设施团队	负责系统的部署、升级、监控、日常运维和故障处理。
	安全运维团队	负责配置安全策略、审计日志、分析风险事件。
决策者/建设方	信息化部门领导	负责技术选型、项目审批、预算控制，关注战略价值与总拥有成本。
	安全与合规部门	负责确保系统满足等保、关基等监管要求，是安全合规性的最终责任方。
受影响方	各业务部门	其使用的业务系统将通过本平台暴露，访问体验和稳定性将受到影响。
	原有系统供应商	其提供的VPN或旧网关方案将被替代。

- 不同角色的关注点是否一致？

员工：体验

IT：可控

运维：可视化+可信

领导层：价值+成本

安全部门：合规

6. 它主要面向哪些典型场景？

填写要点

- 最重要的应用场景有哪些？
- 每个场景是如何触发的，频度如何，价值如何？

1、员工远程与移动办公：最高频、最基础的场景

2、合作伙伴与供应链外联：体现“零信任”细粒度管控价值的标杆场景。

3、核心工程与生产系统暴露：业务部门提出需求，IT 管理员在控制台将某个核心系统（如

bim.company.com)注册到“新云枢”，并配置细粒度访问策略。

4、混合云与跨域统一访问：用户访问一个统一门户，该门户背后应用可能部署在 A 地数据中心、B 公有云等。用户无感知，由网关智能路由。

• 哪些场景必须优先覆盖，哪些场景可以后续扩展？

员工远程办公（基础办公应用）、合作伙伴外联（招采/协同平台）

7. 用户当前最核心的痛点是什么？

填写要点

• 用户现在是怎么做的？

通过“腾讯云枢”（T-Sec SAG/ZTNA）访问（可能有 VPN？）

• 当前方式在效率、质量、成本、风险、可扩展性上存在哪些问题？

维度	存在的问题
效率	1. 依赖公网质量：流量需经腾讯云节点转发，对海外或网络不佳地区，延迟高、体验差，尤其影响BIM大文件上传、视频会议等场景。 2. 接入流程繁琐：尽管优于传统VPN，但仍需多步认证和跳转，移动端和合作伙伴的接入体验仍有优化空间。
质量	1. “黑盒”运维：作为SaaS服务，出现网络抖动、服务降级时，中交IT团队无深度排障能力，只能联系厂商，响应和解决周期不可控。 2. 功能定制困难：无法根据中交特有的业务需求（如与内部达梦数据库联动、定制审计报表）进行深度功能开发或优化。
成本	1. 持续订阅费用：需按用户数或流量支付持续的年度授权费用，总拥有成本（TCO）长期不可控。 2. 隐性成本：因性能或功能限制导致的业务效率损失，是难以量化的隐性成本。
风险	1. 供应商锁定与停服风险：腾讯云枢的停服/强制升级计划，带来了业务中断的确定性风险，这是最迫在眉睫的威胁。 2. 数据主权与安全合规风险：所有访问流量和策略数据经由第三方云平台，存在数据出境和敏感信息泄露的潜在风险，难以满足等保2.0三级和关基条例对“自主可控”的硬性要求。 3. 安全策略僵化：作为通用产品，其安全策略模型可能无法实现中交所需的、极其复杂的、基于“项目-角色-环境-设备”的细粒度动态授权（ABAC），存在过度授权或授权不足的风险。
可扩展性	1. 技术栈锁死：难以与中交正在推进的信创技术栈（如达梦数据库、麒麟操作系统、飞腾芯片）进行深度适配和性能优化。 2. 架构演进受限：无法作为“数字基座”与中交未来的物联网平台、AI分析系统、业务中台等进行低成本、高效率的集成和创新。

• 这些痛点中，哪些是刚性痛点，哪些是可优化痛点？

8. 这个课题最终能带来什么价值？

填写要点

• 直接价值是什么？

直接价值是：实现“零信任”核心能力的国产化、自主化替代，确保业务连续性与基础安全。

• 中期和长期价值分别是什么？

中期价值（1-3 年）：从“可用”到“好用”，构建企业级安全运营能力：精细化安全运营、统一可

观测与审计、成本结构优化

长期价值（3-5 年+）：从“工具”到“平台”，沉淀数字化安全基座能力：赋能业务创新、构建自适应安全架构、能力沉淀与标准输出

• 价值如何体现在客户收益、业务增长、成本降低、风险控制或能力沉淀上？

客户收益：获得一个量身定制、完全受控、可持续演进的核心安全产品，而非标准化商品。其功能、性能、安全策略均可按需深度定制，直接支撑其独特的业务流程和管理模式。

业务增长：通过提供更稳定、更快速、更安全的全球访问体验，保障了全球项目的协同效率。通过安全的 API 开放能力，为孵化和连接新的数字业务提供了可能，间接驱动业务增长。

成本降低：规避长期订阅费，实现采购成本确定性。提升运维排障效率、降低安全事件发生概率和影响面，从而减少业务中断损失和应急响应成本。

风险控制：供应链风险：消除对单一外部供应商的依赖。通过深度防御和细粒度控制，大幅缩小攻击面，提升应对高级威胁的能力。彻底满足“自主可控”的监管要求，规避政策风险。

能力沉淀：为客户的信息化和安全团队沉淀下一整套从设计、开发、部署到运维“零信任安全架构”的完整知识体系、技术组件和人才队伍，这是用钱买不到的、支撑企业未来十年数字化发展的核心内生能力。

9. 现有方案或现状为什么不足以支撑目标？

填写要点

• 现有系统、流程或架构已具备哪些基础？

基础的安全远程接入能力、初步的零信任模型、与企业微信的集成、基本的管控界面

• 哪些能力已经存在但不够用，哪些能力完全缺失？

能力状态	具体表现
已存在但不够用	1. 可观测性 ：现有系统可能提供基础日志，但 缺乏全链路的、标准化的、可用于深度排障和合规审计的细粒度日志与指标体系 （如OpenTelemetry标准）。 2. 性能与体验 ：作为通用SaaS服务，在 特定场景（如海外访问、大文件传输）下的性能和延迟优化能力不足 ，且客户无法自行优化。 3. 策略精细度 ：具备基础的RBAC能力，但 难以实现复杂、动态的ABAC策略 （如“仅允许某项目部的员工，在工作时间，从公司网络，访问特定BIM模型的API”）。
完全缺失	1. 核心技术自主权 ： 完全缺失 对 核心网关、隧道、策略引擎等组件的代码级控制权和定制能力 。这是一个“黑盒”。 2. 与信创技术栈的深度集成能力 ： 完全缺失 与国产数据库（达梦）、操作系统、芯片进行深度适配和性能优化的能力。 3. 内网API的精细治理能力 ：作为一个边界安全产品， 缺失 对进入内网后的流量进行 动态路由、协议转换、高级限流、API全生命周期管理 的“内网API网关”层能力。 4. 东西向服务间零信任 ： 完全缺失 对服务间（微服务A -> 微服务B）通信进行自动mTLS加密和治理的能力，这是零信任的内网延伸。 5. 与自有安全生态的闭环能力 ： 无法 将自身的策略引擎、审计日志与客户内部已有的SOC、4A平台、密钥管理系统等进行深度、灵活的定制化集成。

• 为什么不能通过局部修补解决，而必须做系统性设计？

“黑盒”无法修补、架构代差无法弥合、技术栈锁死无法进化、数据与管控流需要重塑

10. 总体上准备怎么设计？

填写要点		
• 本课题应遵循哪些设计原则？ 分层解耦、职责单一、授权真源、演进可控 • 是性能优先、成本优先、安全优先，还是可运维优先？ 安全优先，兼顾性能、可运维与长期成本的平衡。 • 总体架构准备如何分层，各层职责是什么？见手绘图		
层级	主要职责	不负责什么
Public Edge（公共边缘层）	CDN缓存、WAF基线防护、DDoS缓解。	不做最终业务授权裁决。
Zentinel Edge（零信任边界层）	TLS终止、全局安全防护、粗粒度路由、 零信任准入 （集成Keycloak/OPA/SPIRE）。	不做全功能的互联网级DDoS/WAF。
Private Access（私网接入层）	建立gRPC+mTLS隧道，实现主动出站拨号、连接复用、故障转移。 只做安全传输，不做业务鉴权。	不做业务策略决策。
Intranet API Product（内网API产品层）	细粒度API路由、插件生态（限流/转换/日志）、协议转换、多租户API管理。	不重复实现最终业务授权逻辑（最多做补
East-West Governance（东西向治理层）	服务间L4 零信任 （mTLS）与 L7治理（限流、重试、熔断）。	不替代南北向网关的PDP功能。
Workload Layer（工作负载层）	运行业务逻辑（gRPC服务、消息队列、数据库、AI服务）。	不承担边界安全与控制平面的职责。

11. 系统应拆分成哪些模块？

填写要点	
• 每个模块解决什么问题？	

每个模块解决什么问题？

模块编号	模块名称	核心解决的问题
1	统一接入网关模块	解决“外部流量如何安全、高性能地进入系统”的问题，作为所有请求的统一入口。
2	身份认证模块 (IAM)	解决“用户/设备是谁”以及“如何证明其身份”的问题，实现单点登录和多因素认证。
3	策略引擎模块 (PDP/PA)	解决“谁在什么条件下能访问什么资源”的问题，提供细粒度的动态访问控制（ABAC）决策。
4	应用管理与低代码模块	解决“如何定义和发布一个内网应用以供外部安全访问”的问题，管理应用元数据和映射关系。（当前Demo暂不包含低代码构建）
5	API/Web代理模块	解决“如何在不同协议和网络环境下可靠地转发请求”的问题，是安全流量的传输层。
6	连接器与数据保护模块	解决“如何让内网应用隐身且安全地暴露”以及“如何防止敏感数据泄露”的问题，实现零信任隧道和动态数据脱敏/水印。
7	终端安全代理模块	解决“接入终端是否安全可靠”的问题，进行设备指纹采集和合规性检查。（当前Demo仅预留，不提供深检）
8	审计与风控模块	解决“谁在何时何地做了什么”以及“访问行为是否异常”的问题，实现全链路审计日志和实时风险检测。（当前Demo已搁置大数据部分）
9	管理后台 (Admin Console)	解决“管理员如何便捷地配置和管理整个系统”的问题，提供图形化的配置、监控和排障界面。
10	用户门户 (User Portal)	解决“最终用户如何发现和访问其有权限的应用”的问题，提供统一、友好的应用访问入口。
11	基础设施与部署模块	解决“系统如何高可用、自动化地部署和运行”的问题，提供容器化部署、CI/CD、监控告警等能力。

- 模块边界如何定义，分别负责什么、不负责什么？

模块	负责什么	不负责什么
1. 统一接入网关	TLS终止、全局路由、DDoS/WAF基础防护、与IAM/PDP集成做准入验证。	不做内网API的精细治理（APISIX的职责）、不存储用户会话状态析具体业务协议。
2. 身份认证 (IAM)	用户认证、颁发/验证JWT、管理用户目录、与OIDC提供商（如企业微信）对接。	不做业务权限的最终决策（PDP的职责）、不管理设备证书（SPI责）。
3. 策略引擎 (PDP)	执行ABAC策略规则、返回ALLOW/DENY决策、管理策略缓存。	不执行网络层的转发或拦截、不管理用户身份源。
4. 应用管理	注册应用元数据（名称、内网地址）、建立app_id到上游的映射、管理应用生命周期。	不实现应用本身的业务逻辑、不提供复杂的低代码开发环境（当前阶段）。
5. API/Web代理	协议转换（HTTP<->gRPC）、请求/响应转发、连接池与超时管理。	不做身份认证和授权决策、不对业务数据进行修改或脱敏。
6. 连接器与隧道	建立/维护加密隧道（mTLS）、实现应用隐身、执行数据脱敏/水印策略。	不做路由决策（由控制面下发）、不解析业务逻辑。
7. 终端安全代理	采集设备信息、验证终端合规性、与网关联动进行设备认证。	不进行应用层的病毒查杀或深度行为监控（当前阶段）。
8. 审计与风控	收集全链路日志、格式化存储、提供查询接口、执行预定义的风险规则。	不替代业务系统自身的操作日志、不做实时的主动防御拦截（当前阶段）。
9. 管理后台	提供Web UI进行系统配置、状态查看、用户管理、日志查询。	不包含核心的业务逻辑，仅是控制面的前端展现层。
10. 用户门户	展示用户有权限访问的应用列表、提供单点登录跳转。	不包含应用内的功能，仅是访问的导航入口。
11. 基础设施	提供K8s编排文件、部署脚本、监控面板、告警规则。	不包含业务模块的具体实现代码。

• 模块之间的依赖关系是什么，哪些模块具备独立演进或产品化可能？

主要业务流程：模块 1 -> 模块 5 -> 模块 6 -> 模块 4/3 -> 模块 2 构成了核心的南北向请求处理链。流量按此顺序流转，并依次消费身份、策略等上下文信息。

前后端交互：模块 9 和 模块 10 作为前端，依赖 模块 2、模块 4、模块 3 的后端 API。

日志处理：模块 8 依赖所有其他模块输出的日志流。

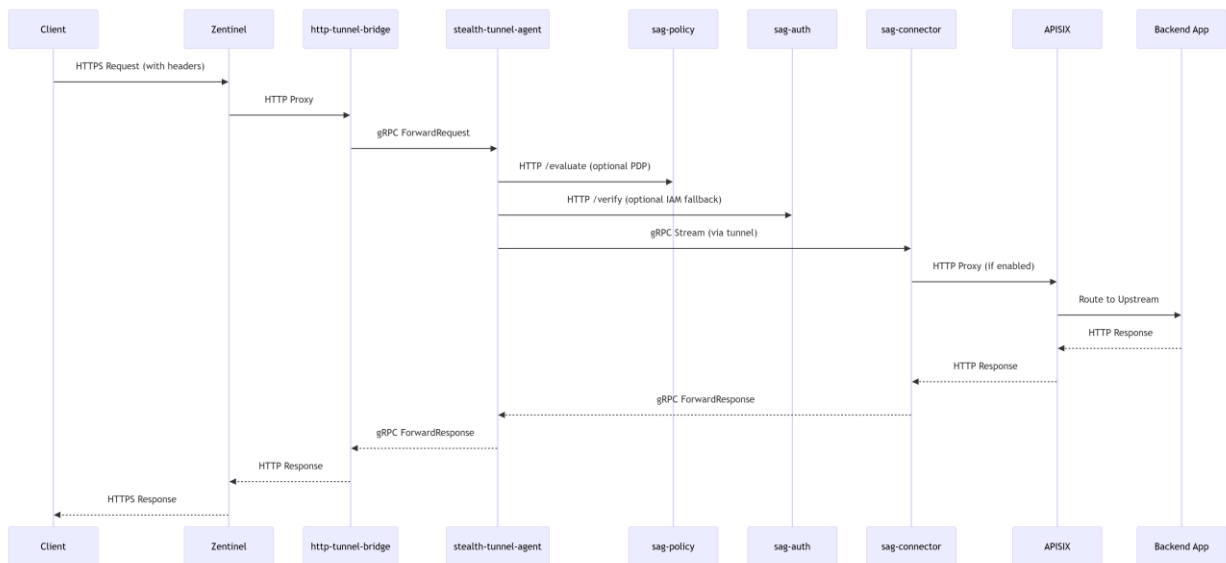
控制台：模块 4(控制平面) 是配置中枢，其变更会影响 模块 1(路由)、模块 6(隧道路由)、模块 3(策略) 和 模块 5(内网上游)。

策略方向：模块 3 的策略决策被 模块 1 和 模块 6 调用。

12. 模块之间如何协作？

填写要点

- 核心接口有哪些？
- 主要的数据流、控制流和状态流如何运转？



- 哪些链路采用同步方式，哪些采用异步方式，异常和失败如何处理？

哪些链路采用同步方式，哪些采用异步方式，异常和失败如何处理？

协作链路	同步/异步	异常与失败处理机制
数据面请求转发 (Zentinel -> ... -> Backend)	同步 (请求-响应)	1. 超时 : 各组件 (Zentinel, bridge, agent) 均有独立超时设置。向上游返回 504 Gateway Timeout 或类似错误。 2. 隧道不健康 : stealth-tunnel-agent检测到对应 connector 跳, 对该 app_id的请求返回 503 Service Unavailable 。 3. PDP/IM 调用失败 : 可配置为 故障闭包 (fail closed) 或 故障开 (fail open)。当前文档未明确, 但 stealth-tunnel-agent已集成编辑。
控制面路由同步 (agent -> control-plane-admin)	同步 (HTTP GET) + 定时轮询	同步调用失败 (网络/服务不可用) 会记录错误日志, agent 使用成功的路由缓存继续运行 , 保证数据面基本可用, 并等待下次重
APISIX 配置下发 (control-plane-admin -> APISIX)	同步 (HTTP POST/PUT)	下发失败会记录错误日志, 并在控制台告警。 控制面会重试 , 直至 APISIX 实际状态达成一致。这是保证配置最终一致性的关键。
隧道心跳 (connector -> agent)	异步 (流式消息)	心跳超时或流中断, agent会将对应隧道标记为不健康, 并关闭 connector会尝试 重连 。这是隧道高可用的基础。
审计日志 (各组件 -> 中心)	异步 (文档中已搁置, 但为典型设计)	日志发送失败不应阻塞主流程。通常采用 本地缓冲 + 异步批量发 消息队列 (如Kafka) 或日志收集器, 由下游消费者保证可靠性。

13. 核心数据对象应该如何定义？

填写要点

- 有哪些关键对象、关键字段和唯一标识？
- 对象之间是什么关系？
- 数据如何分层，如何满足权限、脱敏、生命周期和审计要求？

对象名称	描述	关键字段与唯一标识	所在服务
------	----	-----------	------

User (用户)	系统使用者。	id (PK) : 全局唯一用户标识。 username : 登录名。 password_hash : 密码哈希 (Argon2)。 roles : 角色列表 (如 ["admin"])。 email/phone : 联系信息。 status : 状态 (启用/禁用)。	sag-auth (本地目录) 或 外部 IdP (如 Keycloak)。
Policy (策略)	访问控制策略规则。	id (PK) : 策略 ID。 effect : 决策结果 ("ALLOW"/"DENY")。 subjects : 主体列表 (如 ["u-admin"] 或 ["role:finance"])。 app_id (可选): 应用 ID。 path_prefix (可选): 路径前缀。 priority : 优先级 (数值)。 conditions (可选): 附加条件 (JSON, 如时间、IP)。	sag-policy (存储于 SQLite)。
TunnelRoute (隧道路由)	定义外部请求如何路由到内部连接器。	host (PK) : 外部访问域名 (如 app.internal.com)。 app_id : 关联的应用 ID。 connector_endpoint : 连接器端点标识 (如 connector-local-001:stream)。 require_healthy_tunnel : 布尔值, 隧道不健康时是否拒绝请求。	control-plane-admin (存储于 SQLite, 同步至 stealth-tunnel-agent)。
IntranetUpstream (内网上游)	定义 app_id 映射到的真实内网服务地址, 用于下发至 APISIX。	app_id (PK) : 应用 ID。 target : 上游目标地址 (如 http://10.0.1.100:8080)。 scheme : 协议 (http/https)。 status : 状态 (启用/禁用)。	control-plane-admin (存储于 SQLite, 下发至 APISIX Admin API)。
Connector (连接器实例)	代表一个内网中运行、主动出站连接的代理实例。	connector_id (PK) : 连接器唯一标识 (如 connector-local-001)。 app_id : 所代理的应用 ID。 external_host : 对外服务域名。 status :	stealth-tunnel-agent (内存中维护)。

		在线状态（基于心跳）。 last_heartbeat: 最后心跳时间。	
AuditLog（审计日志）	记录所有关键操作和访问。	log_id (PK): 日志 ID。 timestamp: 事件时间。 event_type: 事件类型（LOGIN, POLICY_EVAL, ACCESS）。 user_id: 操作用户。 app_id: 涉及应用。 resource: 访问资源。 action: 操作动作。 result: 结果（成功/失败）。 client_ip: 客户端 IP。 details: 详细上下文（JSON）。	各服务输出，由 Audit/Risk 模块（未实现）统一收集存储。

14. 为什么选择这套技术方案和实现路径？见技术栈选型腾讯文档

<https://docs.qq.com/aio/DUGNTdHBmeGpDZGVx>

填写要点

- 有哪些候选方案？
- 最终选型的依据是什么？
- 在性能、成本、复杂度、扩展性、兼容性和未来演进上，为什么当前方案更合适？
- 对比调研？

15. 如何分阶段落地，并证明方案成立？

<https://docs.qq.com/aio/DUG9kQU1YakxMVWt3?AIGenerate=1&yb=1&p=ch1UZPxVmM5rmo4liCFIIm>

填写要点

• MVP 范围是什么？

最小可行产品（MVP）的范围是：交付一个能够在中交集团测试环境中，安全、稳定地承载 1-2 个非核心内网应用访问的零信任网关系统，并具备完整的管理控制台。

具体包括以下 11 模块中的核心子集：

- 数据面：模块 1（Zentinel 网关）、模块 5（http-tunnel-bridge）、模块 6（stealth-tunnel-agent + connector）、模块 2/3（基础 IAM/PDP）。
- 控制面：模块 4（简化版应用管理，即 control-plane-admin 的 API）。

- 前端：模块 9/10（可运行的管理后台和用户门户 Demo）。
- 数据持久化：基于 SQLite 的配置存储。（后续开发数据库适配器，适配达梦等国产数据库）
- 可选集成：与 APISIX 的基础集成（作为内网流量治理的可选项）。

明确排除在 MVP 外：模块 7（终端深检）、模块 8（大数据风控）的复杂实现，以及模块 4 的低代码构建功能。

• 每个阶段分别交付什么、验证什么价值？

阶段	阶段名称	核心交付物	价值验证点	进入下一阶段条件（出口标准）
阶段一 (1-4 周)	核心链路闭环与配置持久化	1. 稳定的 端到端数据面链路 （Zentinel->隧道->应用）。 2. 所有配置（路由、策略、上游） 持久化至 SQLite 并可通过 API 管理。 3. 控制面配置可自动同步至 APISIX （若启用）。 4. 更新后的 部署与运维手册 。	验证 技术可行性 和 基础可运维性 。 证明新架构在功能上可对标旧系统核心链路。	1. smoke-dataplane 脚本 100%通过 。 2. 所有核心服务重启后 配置不丢失 。 3. 甲方技术团队可 依据手册独立完成部署和基础功能测试 。
阶段二 (4-8 周)	生产环境 POC 与试点	1. 在中交测试环境的 生产等价服务器 上完成部署。 2. 接入 1-2 个 真实的非核心业务系统 （如内部知识库、测试环境 0A）。 3. POC 测试报告 ，包含性能、安全、功能对比数据。 4. 初步的 运维监控看板 （基于 Prometheus/Grafana）。	验证 生产就绪度 和 用户价值 。证明系统在真实环境下稳定可用，且用户体验不劣于腾讯云枢。	1. 试点系统 稳定运行 72 小时 无重大故障。 2. 核心用户（试点部门）反馈 访问体验达标 。 3. 性能测试结果 满足预定义基准 （如 QPS、延迟）。 4. 获得甲方对 POC 结果的 书面认可 。
阶段三 (8-12 周)	正式交付与能力转移	1. V1.0 正式发布包 （含所有二进制、配置、部署清单）。 2. 完整的技术文档、运维手册、 故障处理预案 。 3. 甲方运维团队的 现场培训 与知	验证 产品成熟度 和 可交付性 。证明系统已具备替代旧系统、承担核心业务流量的能力，且客户能自主运维。	1. 甲方运维团队能 独立完成系统巡检、配置变更和故障恢复 。 2. 完成 核心应用迁移方案 的评审并获得

		识转移。		授权。
		4. 支持从腾讯云枢灰度迁移 1 个核心应用的详细方案。		3. 签署项目初验报告。

- 有哪些关键风险、外部依赖、未决问题，以及什么条件下可进入研发、试点或正式交付？

类别	具体内容	缓解措施
关键风险	1. 性能风险 ：Rust 组件在生产负载下出现未预见的性能瓶颈或内存泄漏。 2. 兼容性风险 ：与中交特定的老旧业务系统或国产化软硬件存在兼容性问题。 3. 迁移风险 ：从腾讯云枢迁移时，业务中断或配置错误导致的服务不可用。 4. 运维风险 ：客户运维团队对 Rust 技术栈和云原生架构不熟悉，导致运维困难。	1. 阶段二进行充分的压力测试和长时间稳定性测试。 2. 在 POC 阶段尽早接入各类典型业务系统进行兼容性验证。 3. 制定详尽的灰度迁移、回滚预案和演练计划。 4. 提供详尽的文档、培训，并在阶段三提供驻场运维支持。
外部依赖	1. 甲方资源 ：测试环境资源、试点业务系统接口人、运维团队参与度。 2. 信创环境 ：国产 CPU、操作系统、数据库的适配与调优，可能需芯片/OS 厂商支持。 3. 第三方服务 ：如果使用 Cloudflare 等商用 CDN/WAF，其服务可用性与配置复杂度。	1. 在项目启动时明确并锁定甲方各接口人及职责。 2. 将信创适配作为 独立验证项 ，提前与相关厂商建立沟通渠道。 3. 对第三方服务制定 降级方案 （如回源到 Zentinel）。
未决问题 (当前)	1. Zentinel Windows 编译问题 ：proxy/core 在 Windows/MSVC 下因 Unix Socket 代码路径编译失败。 2. 审计日志规范 ：审计日志的具体格式、输出方式和聚合方案尚未最终确定。 3. 高级策略场景 ：复杂 ABAC 策略（如跨部门、动态属性）的性能和测试用例	1. 已有明确结论 ：生产环境使用 WSL/Linux 运行 Zentinel，此问题不影响交付，但需在部署手册中明确。 2. 在阶段一明确 审计日志标准 （如采用 OTe1），在阶段二实现基础采集。 3. 在阶段一完善策略引擎测试，在阶段二用真实业务需求验证复杂策略。

	待完善。	
进入下一阶段条件	研发->试点：完成阶段一出口标准，并获得甲方对 POC 范围与目标的确认。 试点->交付：完成阶段二出口标准，特别是获得甲方对 POC 结果的书面认可，并共同评审通过迁移方案。 交付->维保：完成阶段三出口标准，签署初验报告，并移交全部交付物。	建立阶段门评审机制，每个阶段结束后，由甲乙双方基于出口标准清单进行评审，评审通过后方可进入下一阶段。